

1. Методы авторизации

Документ для экспертов и администраторов: как войти в систему, как устроены вход, сессия и права, как завести учётную запись эксперту и как устроен доступ между сервисами и к инфраструктуре. Состояние — на 29.09.2026.

Где код. tf-auth — [think-auth@prod](#), права — [think-bff@prod](#), интерфейс — [think-front@prod](#), инфраструктура — [think-infra@dev](#), концепт прав и аудита — [Think-Faster: docs/common/права-и-аудит.md](#).
Подробные разделы сервисов — [SYSTEM.md](#), [Часть III](#).

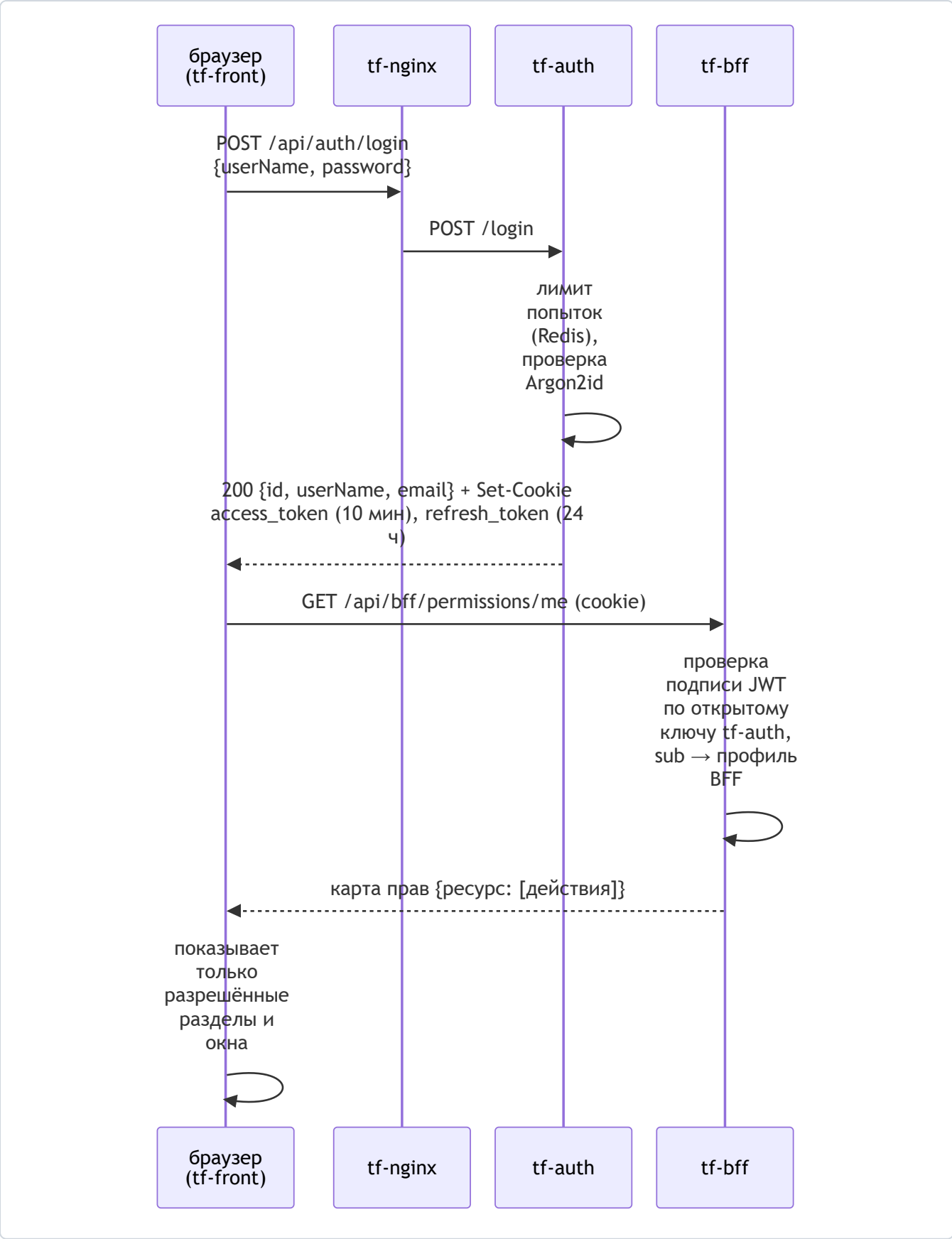
1.1. Куда входить

Стенд	Адрес	Назначение
prod	https://thinkfaster.ru	демонстрационный стенд для экспертизы
dev	https://greefob.ru	стенд разработки, поток событий от эмулятора

Браузеры: актуальные Google Chrome и Яндекс.Браузер (T3 §11). Соединение — только HTTPS: nginx принимает TLS 1.2 и 1.3 ([web-server/nginx/nginx.conf.template](#), `ssl_protocols TLSv1.2 TLSv1.3`). Запросы по HTTP перенаправляются на HTTPS.

Учётные данные экспертов в документе не публикуются: их выдаёт команда отдельно. Как их заводит администратор, описано в разделе 1.5.

1.2. Вход пользователя



Шаг	Метод	Где в коде
Форма входа	POST /api/auth/login {userName, password}	фронт: app/src/features/auth/LoginForm.tsx ; tf-auth: AuthService/WebAPI/Controllers/AuthController.cs
Проверка пароля	Argon2id (соль 16 байт, память 64 МБ, 3 итерации)	AuthService.Cryptography/Services/Argon2PasswordHasher.cs
Лимит попыток	5 неудач за 60 с по паре «IP + логин» → 429 + Retry-After	WebAPI/Services/RateLimit/RedisRateLimitService.cs
Выдача токенов	JWT RS256, kid: main-key, iss=auth-service, aud=api	AuthService.Cryptography/Services/TokenService.cs
Cookie	access_token и refresh_token : HttpOnly, Secure, Path=/ ; SameSite — Lax и Strict	AuthService.Cryptography/Services/AuthCookies.cs
Продление сессии	POST /api/auth/refresh ; BFF продлевает сам, когда видит просроченный access	tf-auth AuthController.cs ; BFF TokenAuthenticationMiddleware.cs
Текущий пользователь	GET /api/auth/me	WebAPI/Controllers/UserController.cs
Выход	POST /api/auth/logout — удаляет cookie (ветка TF-Auth-Logout, в prod с 29.09)	AuthController.cs
Журнал	login.success, login.failure, account.locked, token.refreshed, user.created, access.denied → поток Redis audit	WebAPI/Services/Audit/AuditWriter.cs

Токен доступа живёт 10 минут, токен обновления — 24 часа. Токены на сервере не хранятся. Пароли, токены и cookie в журнал не пишутся.

Состав токена доступа

```
{ "sub": "<uuid пользователя>", "typ": "access", "token_type": "access", "kind": "user",
  "login": "ivanov", "jti": "<uuid>", "exp": 1790630965, "iss": "auth-service", "aud": "api" }
```

Ролей и прав в токене нет **сознательно**. tf-auth отвечает на вопрос «кто это», а BFF — на вопрос «что ему можно»: права берутся из базы BFF с кешем. Если человека перевели в другую группу, это начинает действовать без пере выпуска токенов.

1.3. Права: RBAC в BFF

Права выдаются **группам** на **ресурсы**. Пользователь получает объединение прав всех групп, в которые он входит, включая вложенные.

Понятие	Что это	Где
Ресурс	область данных: objects, sensors, predictions, tasks, incidents, readings, schedule, assigned_objects, engineers, presence, users, groups, permissions, model_settings, notifications	BFF/scripts/001_seed_initial_data.sql
Действие	битовая маска: Create=1, Read=2, Update=4, Delete=8, Export=16, Import=32, Manage=64 ; Manage покрывает всё	BFF.Models/Enums/PermissionFlags.cs
Грант	«группа или пользователь × ресурс × маска»	таблица access_grants

Понятие	Что это	Где
Группа	может содержать людей и другие группы; дерево хранится замыканием <code>group_closure</code>	GroupsController.cs
Проверка	атрибут <code>[RequirePermission(ресурс, действие)]</code> на каждой ручке, политика строится на лету	BFF.WebApi/Authorization/
Кеш прав	300 с, сбрасывается сменой <code>rbac_version</code> (опрос раз в 5 с)	PermissionCache.cs
Интерфейс	окно показывается, только если есть хотя бы одно из требуемых прав	app/src/core/registry/windowRegistry.ts

Роли и что можно выдать — документ [2. Архитектура](#), раздел 2.5.

Ошибки доступа, которые увидит пользователь:

Код	Когда
401 <code>unauthenticated / invalid_token / token_refresh_failed</code>	нет сессии, токен повреждён, продлить не удалось → экран входа
403 <code>user_not_provisioned</code>	учётка в tf-auth есть, профиля в BFF нет
403 <code>user_inactive</code>	профиль отключён
403 (право)	нет права на ресурс или действие

1.4. Проверка токенов другими сервисами

Все сервисы проверяют токен сами, без обращения к tf-auth за каждым запросом: открытый ключ скачивается с `http://tf-auth:8080/.well-known/jwks` и кешируется. Ответ — **PEM** открытого ключа, не JSON JWKS.

Сервис	Что проверяет	Код
tf-bff	подпись, <code>iss</code> , <code>aud</code> , срок (сдвиг 30 с), <code>sub</code> → профиль	JwtValidator.cs
tf-funnel	RS256, <code>aud=api</code> , <code>iss</code> ∈ {auth-service, tf-auth}, <code>typ=access</code> ; право шины <code>telemetry.push</code>	docs/backend/funnel/kit.go
tf-model, tf-audit	то же (общий пакет tfkit); техучётка — <code>kind: service</code> , <code>scope</code> или <code>sub</code> из списка	docs/backend/tfkit/tfkit.py

Техучётки. Концепт предусматривает для сервисов токены с `kind: service` и списком разрешённых действий `scope` ([права-и-аудит.md §2–3](#)). В tf-auth их **пока нет**: все токены `kind: user`, без `scope`. Как это обходится:

- tf-funnel принимает `sub` учётки шины из списка `TF_FUNNEL_SERVICE_SUBS` (Vault `app/tf-funnel`);
- tf-model (`/forecast`, `/history`) и tf-audit (`/events`) обхода нет, эти ручки пока недоступны.

План — [SYSTEM.md, Часть VIII, № 4](#).

1.5. Как завести учётку эксперту

Нужны два шага: учётка в tf-auth («кто это») и профиль с группой в BFF («что ему можно»).

1. **Учётка.** Администратор с признаком `SuperUser` в `tf-auth` открывает окно «Пользователи и группы» → «Новый пользователь». Фронт вызывает `POST /api/auth/create {userName, email, password}` и получает `id`.
2. **Профиль.** В том же окне создаётся профиль BFF (`POST /api/bff/users`) с `authUserId = id` из шага 1.
3. **Права.** Профиль добавляется в группу (`POST /api/bff/groups/{id}/members`). Для экспертов рекомендуется отдельная группа `experts` с правом `Read` на все ресурсы, кроме `users` и `permissions`. Так эксперт видит всё, но ничего не меняет.
4. Проверка: вход под новой учёткой, `GET /api/bff/permissions/me` возвращает карту прав.

Первый администратор создаётся при развёртывании: сидинг BFF заводит группу `admins`, а признак `SuperUser` в `tf-auth` выставляется SQL-запросом ([SYSTEM.md](#), [tf-auth §9](#)).

1.6. Проверка API вручную

Все ручки работают с cookie так же, как браузер. Пример для терминала (пароль спрашивается и не остаётся в истории команд):

```
read -rs -p "Пароль: " P; echo; curl -s -c jar.txt -H 'Content-Type: application/json' -d "{ \"userName\": \"<логин>\", \"password\": \"$P\" }" https://thinkfaster.ru/api/auth/login; unset P
```

```
curl -s -b jar.txt https://thinkfaster.ru/api/bff/permissions/me
```

```
curl -s -b jar.txt "https://thinkfaster.ru/api/bff/predictions?page=1&pageSize=10"
```

```
curl -s -b jar.txt https://thinkfaster.ru/api/ml/status
```

Без входа: `https://thinkfaster.ru/api/funnel/health`, `https://thinkfaster.ru/api/ml/health`, `https://thinkfaster.ru/api/auth/health`. После проверки удалите `jar.txt`: в нём действующая сессия.

1.7. Корпоративный каталог (LDAP / AD)

ТЗ §11 требует поддержки интеграции с LDAP/AD.

- **Есть:** контроллер домена Samba AD (realm `TF.GREEFOB.RU`, LDAP 389, Kerberos 88) — [think-infra: samba/](#). Он собирается и настраивается, но в выкатку стендов не входит.
- **Нет:** входа через каталог в `tf-auth`. Схема перехода описана в концепте ([права-и-аудит.md §5.1, вариант B](#)): учётка отделяется от способа входа (`password | ldap`), а группа BFF получает поле `external_ref` на группу AD. Это одна миграция в `tf-auth` и сопоставление групп в BFF.

1.8. Доступ к инфраструктуре (администраторы)

Что	Как	Документ
Серверы стендов	SSH по ключу	SYSTEM.md, 4.7
Секреты (Vault)	личный токен <code>tf-admin</code> ; веб-интерфейс <code>https://vault.greefob.ru</code> (dev) или SSH-туннель	SYSTEM.md, 2.3, 4.6

Что	Как	Документ
Сервисы → Vault	AppRole <code>tf-svc-<сервис>: role_id + secret_id</code> из GitHub Environment	hashicorp/services.conf
PostgreSQL	dev — адрес dev-сервера, порт 5432 (выдаёт администратор стенда); prod — SSH-туннель на <code>127.0.0.1:15432</code> ; пользователи схем <code>*_user</code> / <code>*_admin</code>	SYSTEM.md , 2.5, 4.7
RabbitMQ UI	SSH-туннель на <code>15672</code> , пользователь <code>admin</code>	rabbitmq/REAMDME.md
Выкатка из GitHub	пары AppRole в Environments <code>dev</code> / <code>prod</code> репозитория	06. Деплой

1.9. Известные ограничения

Что	Риск	Статус
POST <code>/api/auth/register</code> открыт всем	создание учёток посторонними (данных без профиля в BFF они не увидят)	закрыть на prod — SYSTEM.md VIII-5
Лимит попыток и IP в журнале берутся от адреса <code>nginx</code> или из подменяемого <code>X-Forwarded-For</code>	блокировка чужого логина, недостоверный IP	SYSTEM.md VII-3 , VIII-6
Нет техучёток и <code>scope</code>	шине и межсервисным вызовам нечем получить долгий токен	SYSTEM.md VII-1
Один ключ подписи без ротации с перекрытием	смена ключа разлогинивает всех	SYSTEM.md VII-6